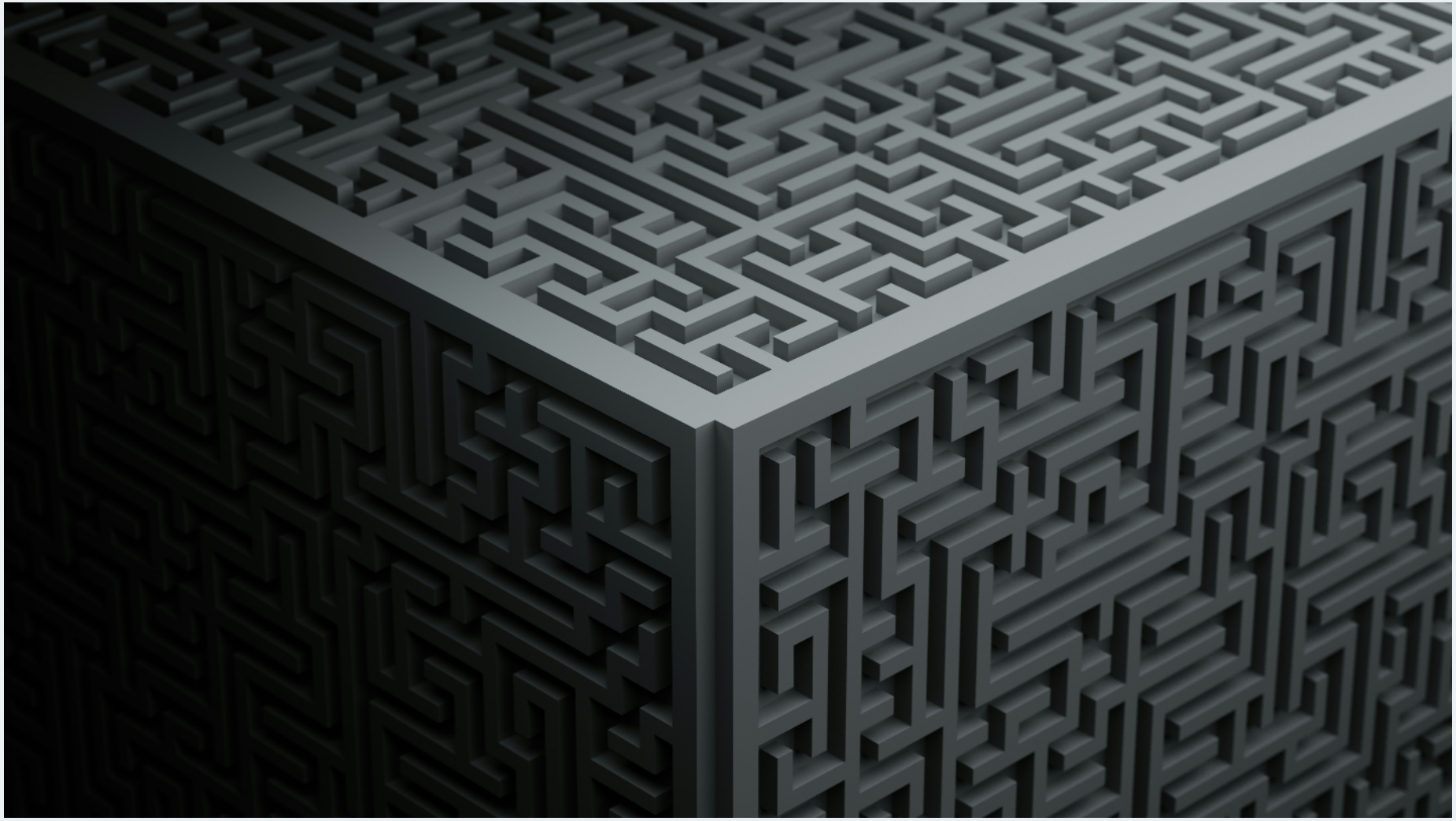
ROMHACK 2026 CAMP

When IaC Goes Wrong

Sean Juroviesky

They/She
Security Architect

Is Infrastructure as Code a Mistake?



Or is the issue lifecycle management?

- People change teams or leave
- Resources are moved elsewhere
- The end of the lifecycle isn’t mapped
- Services end up orphaned

How do we end the cycle?

Ending the Cycle

- IaC's Promise
- Our Misadventures
- Successes
- Applying it IRL



IaC’s Promise

The promise

- Speed - Rapid deployment of resources, less manual process
- Consistency - Set deployment functions, centrally managed parameters
- Security - Default known good, each components already been reviewed
- Documentation - It’s right there in the code, so it documents itself

Worldwide recognition

- Used by all MANGO companies
- The promise seems to be realized!
- Our inheritance: Self-healing infrastructure, quick secrets management, modular tools

But what happens when those gifts become stale???


SECURITY
CSS
HTML
QUIET
php
git
LARACON
NODE
node

Our Misadventures

Problems

Slow and Inconsistent:

The right module doesn’t exist, or devs are unaware of it, do they:

A, Write one that fits their needs

B, Click-ops it

C, Vibe-code it

Problems cont’d

Security and Documentation:

You find an active service with a well known CVE hasn’t been updated, why:

A, The self-documenting IaC says newer versions have a compatibility issue, but it’s been mitigated with X

B, You manually chase down the dev in git blame

Problems cont’d

Documentation

The correct test doesn’t exist; who writes it and reviews it:

A, The author writes the test, then submits it to production

B, A teammate validates the test, and it’s submitted to a development environment to verify

What's the theme?

- Failures to prepare, be consistent, and communicate:
  - Ill-prepared: Partial pictures, incomplete roadmaps, unknown variables
  - Inconsistent: Click-opsing as needed
  - Incommunicative: Unvoiced issues, siloed teams

It’s *easy* to start before you’re ready



Ill-Prepared

- Rolling out of IaC for a service without knowing everything affected by the service
- Missing tools used by a service, or finding that Terraform is buggy with them
- Lifting and shifting, instead of modernizing

A critical service was moved to Terraform, you've automated rebuilding, but overlooked alerting. - So you don't know it's been down for hours

Inconsistency

- Overlooked resources and scenarios, incentivize click-ops
- Click-opsing means it’s not in git-blame
- One-off exceptions pile up

Repos can only be created with the: Repo Creation Function

Except, if x is true

Incommunicative

- Not informing every stakeholder of transitions
- Sudden due dates or changes without telling the entire project team
- Training and documentation, written for yourself

Is the documentation and training written by a single author? Does it account for varying technical audiences and every team that needs to understand it?

Everyone communicates in their own way



Successes!

Successes

- Two projects I’d like to showcase are:
  - Communication: documentation built-in at the commit
  - Consistency: Using an identity provider as the source of truth

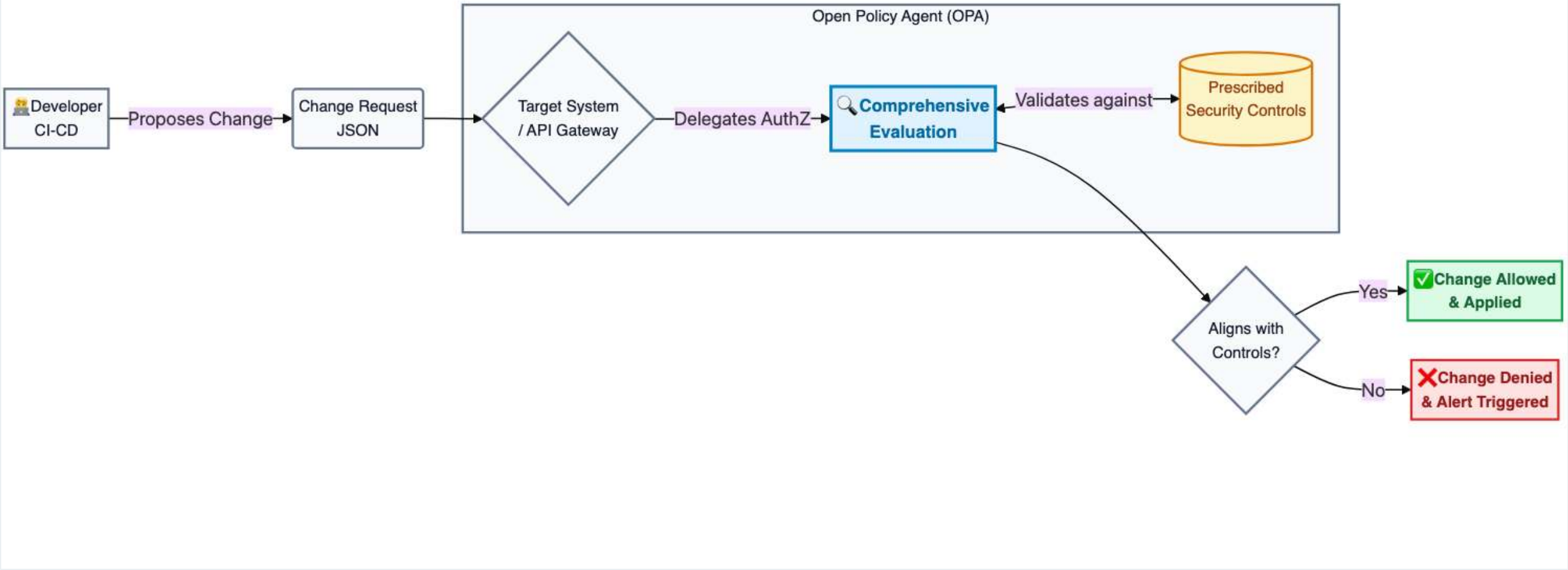


Communication/Documentation



- Problem: No one was updating the data flow diagrams
- Utilizing OPA (Open Policy Agent) we:
- Scan IaC changes for updates to infrastructure or new infrastructure
- That's processed into a JSON file, and converted into a diagram with Excalidraw's API
- Altogether creating a minimal effort documentation system

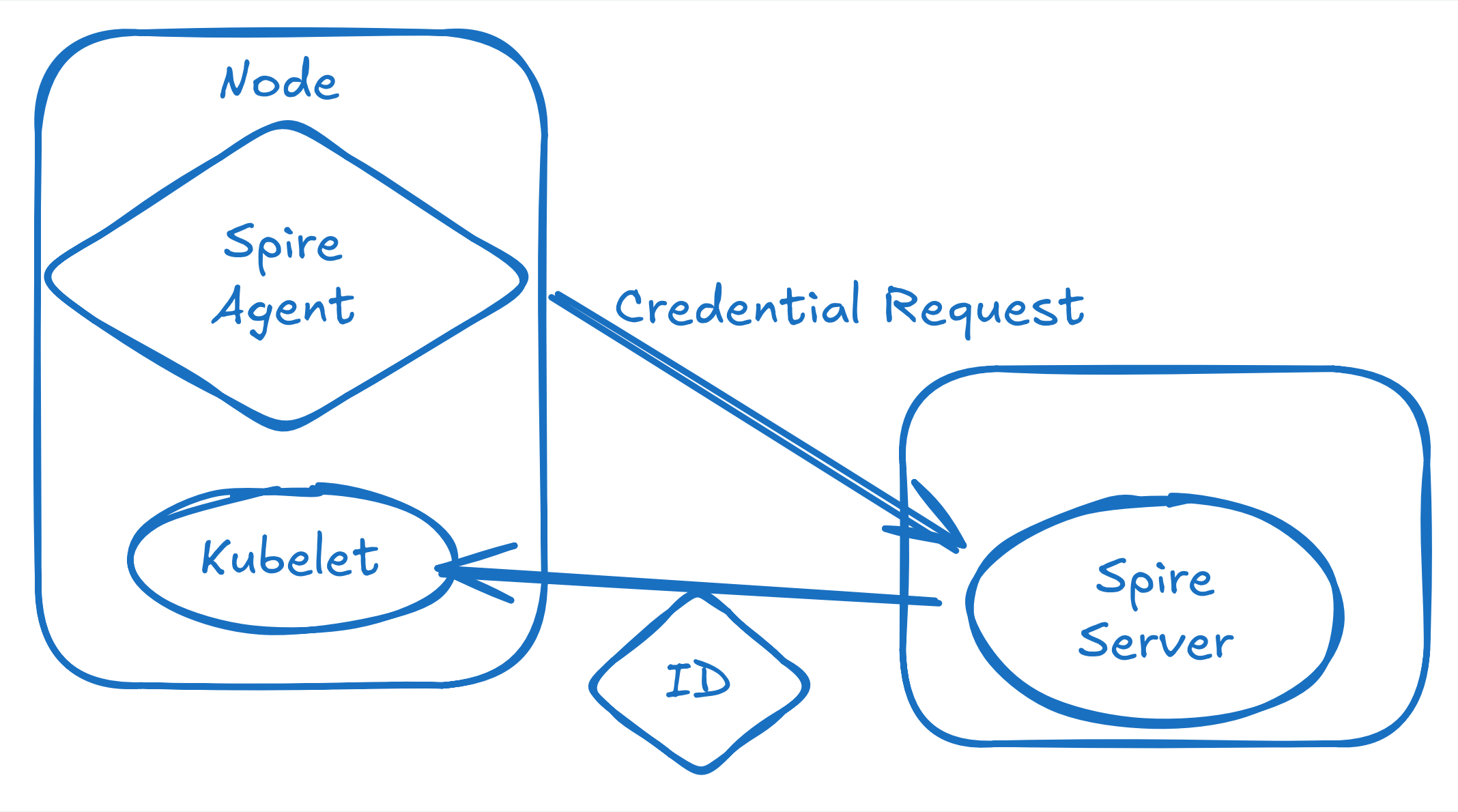



Open Policy Agent (OPA)
Developer
CI-CD
Proposes Change
Change Request
JSON
Target System
/ API Gateway
Delegates AuthZ
Comprehensive
Evaluation
Validates against
Prescribed
Security Controls
Aligns with
Controls?
Yes
Change Allowed
& Applied
No
Change Denied
& Alert Triggered

Consistency

- Problem: Permissions for workloads and services are defined and set in multiple locations
- Solution: Implement a SPIRE CA to act as the source of truth for machine identity
- Devs don’t need to manage credentials
- Short-lived certs replace hard-to-track secrets




Node
Spire
Agent
Credential Request
Kubelet
ID
Spire
Server

Theme of PCC

- Failures to prepare, be consistent, and communicate:
  - Prepared: IaC doesn’t work without Mise en Place
  - Consistent: If half your work is click-ops you’re not an IaC shop
  - Communicative: Voice your needs, and build as a team not a silo

How to actually use this rant

- Prepare: Review what you have and where you are
- Consistent: Document common exceptions
- Communicate: Find *everyone* that isn't in the loop

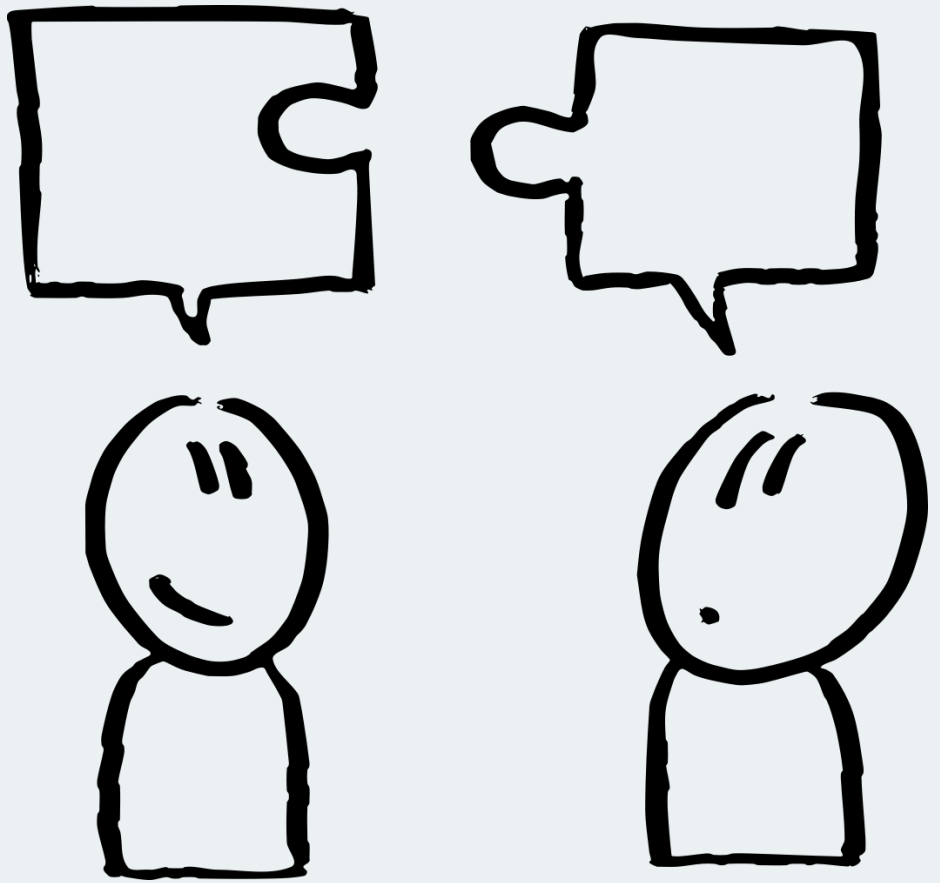


Prepare/Consistent

- Review and document how you usually build infrastructure
- Find or create a policy for how IaC should be used
- Find common click-ops, exceptions, anything repeatedly outside of policy

Communicate

- Decipher everyone with a stake in IaC
- Ensure they have access to communications and documentation
- Establish who they should direct issues, ideas, needs, or complications to



Longer Term

- Prepare: Integrate mise en place into your team
- Consistent: Make consistency the easy road
- Communicate: Keep a dialogue that works for all



Prepare

- Help your team build a habit of establishing their readiness
- Create a process for teams to establish readiness before a large change is made
- Add it as a build requirement, your change committee, or wherever you think it will have the *right* impact



Consistency

- Track exceptions to policy, and build modules/tools to eliminate them
- Use convenience to incentivize consistency, if:
  - Credentials can be granted via template or JIT; what will a dev choose?
  - Bake linting into your make plans, so tests don’t require unnecessary back and forth

Consistency Cont’d

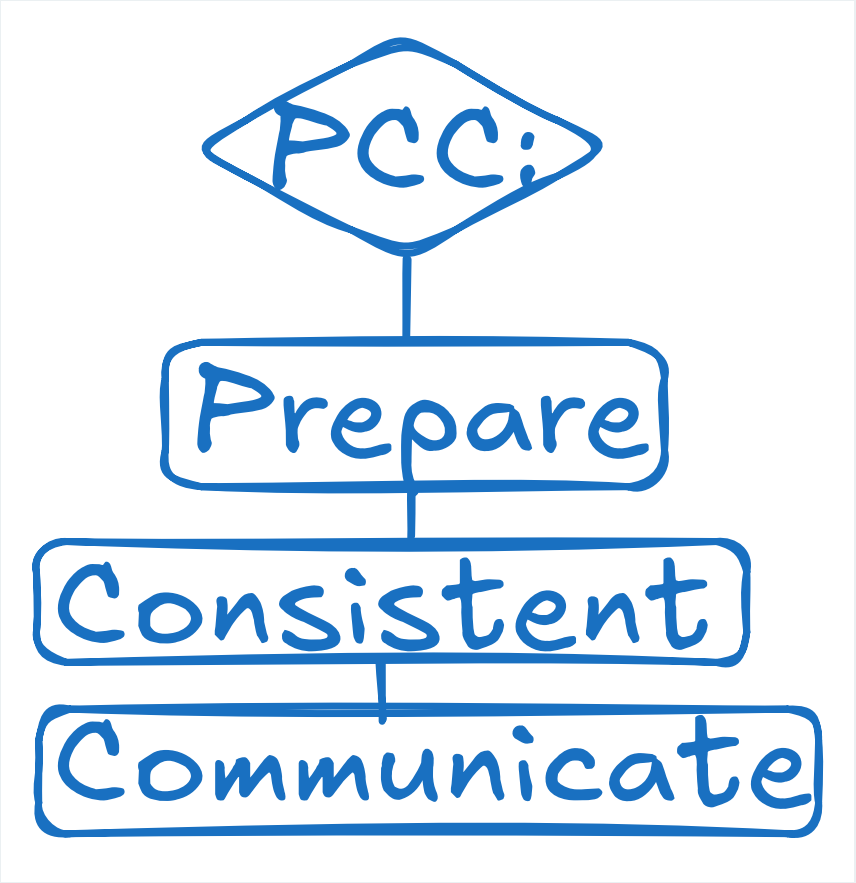
- Make the secure path the path of least resistance
- Eat your own medicine; security needs to follow the same rules



Communicate

- A dialogue that works for all
- It takes effort to ensure that everything being communicated is understood
- To facilitate clear communication, normalize inquizitive questions, ask specific open-ended questions, lead by example

Fin



- Review your policies and procedures
- Practice clear and active communication
- Build preparatory rituals into your team's work
- Build evaluations, and convience into your secure path

Grazie per avermi ospitato.